

CPE334 - Software Engineering

Lab 3: TokTickIT

Final-main verification: all checks passed

Lathapol Srikhiao - 67070503475

Reviewer: Kittakorn Pongpien - 67070503401

[GitHub repository](#)

Prepared 16 September 2026

This submission follows the nine answer parts in the Lab 3 handout and the simple layout of the supplied Lab 2 submission. All feature and cleanup PRs were peer reviewed and merged into lab3-staging, then PR #47 released them to main. All checks passed on main commit 43e6c0605766586f7bacafde882da1a06ab1e9c2. The reflection is AI-assisted; test execution is attributed to the assistant.

Answer Part 1: Git workflow

Answer Part 2: Specification-driven development

Answer Part 3: Tests and traceability

Answer Part 4: AI use and reflection

Answer Part 5: Authentication and requester UI

Answer Part 6: IT Staff queue

Answer Part 7: Ticket workflow and communication

Answer Part 8: Administrator users

Answer Part 9: Zen Green and responsive UI

Answer Part 1

Git workflow and review

[Repository source](#)

Lab 3 review record

Author: Lathapol Srikhiao - 67070503475 (@Lathapol). Reviewer: Kittakorn Pongpien - 67070503401 (@Kittakorn-P). Identity details are from the supplied Lab 2 submission; Lab 3 approvals below are independently verified on GitHub.

Contract, feature, cleanup and main release reviews completed. Final-main verification passed on 2026-09-16.

Reviewer identity	PR link	Review comment	Author response	Approval
Kittakorn-P	PR #36	"All the spec and the scope of lab3 looks good. ready to start the work now"	"ok thanks, i'll start issue 2 now"	Approved and merged into lab3-staging, 2026-09-12

Review focus: contract decisions, additive migration, auth/session/CSRF, direct role/ownership tests, note privacy, concurrent admin safety, requester regression and responsive evidence. Feature PRs target lab3-staging; integration PR targets main after review.

Kittakorn-P approved [PR #40](#): "All issue2 done correctly. ready to merge". Merged 2026-09-13. Author response: "ok thanks, i'll continue issue3 now".

Kittakorn-P approved [PR #41](#): "All file change was done right. merge now and ready for next part". Merge verified 2026-09-15. Author response: "ok thanks, i'll continue issue4 now".

Kittakorn-P approved [PR #42](#): "Ticket Queue both frontend and backend work fine. ready to go". Merge verified 2026-09-15. Author response: "ok thanks, i'll continue issue5 now".

Kittakorn-P approved [PR #43](#): "Workflow done correctly. ready to go". Merge verified 2026-09-15. Author response: "ok thanks, i'll continue issue6 now".

Kittakorn-P approved [PR #44](#): "All and all work fine. UI artifacts is correct too. merge and go next". Merge verified 2026-09-15. Author response: "ok thanks, i'll continue issue7 now".

Kittakorn-P approved [PR #45](#): "All test work fine". Merge verified 2026-09-15. [Author response](#): "ok thanks, i'll prepare issue8 now".

Kittakorn-P approved [PR #46](#): "All thing mention is include. well done. ready to merge". Merged as 5b03d87d1ff9ebf351e859d3d8171ece2d33d65b. [Author response](#): "ok thanks, i'll open the main release pr now".

Kittakorn-P approved [PR #47](#): "All feature was add. merge main now". Merged lab3-staging into main as 43e6c0605766586f7bacafde882da1a06ab1e9c2. [Author response](#): "ok thanks, i'll run the final main tests and finish the pdf now".

[Repository source](#)

lab3 issue8 : Release integration and submission

PR #46 delivered setup/ignore cleanup and the submission draft. Kittakorn-P approved and merged it into lab3-staging. PR #47 was approved and merged lab3-staging into main.

Final-main commit: 43e6c0605766586f7bacafde882da1a06ab1e9c2.

On 2026-09-16, all 13 server suites / 160 tests, 7 client files / 26 tests, 15 browser scenarios, server/client type checks and Vite build passed on that exact main commit. Full logs and commands are in artifacts/lab-03/verification. Browser evidence was refreshed by that run.

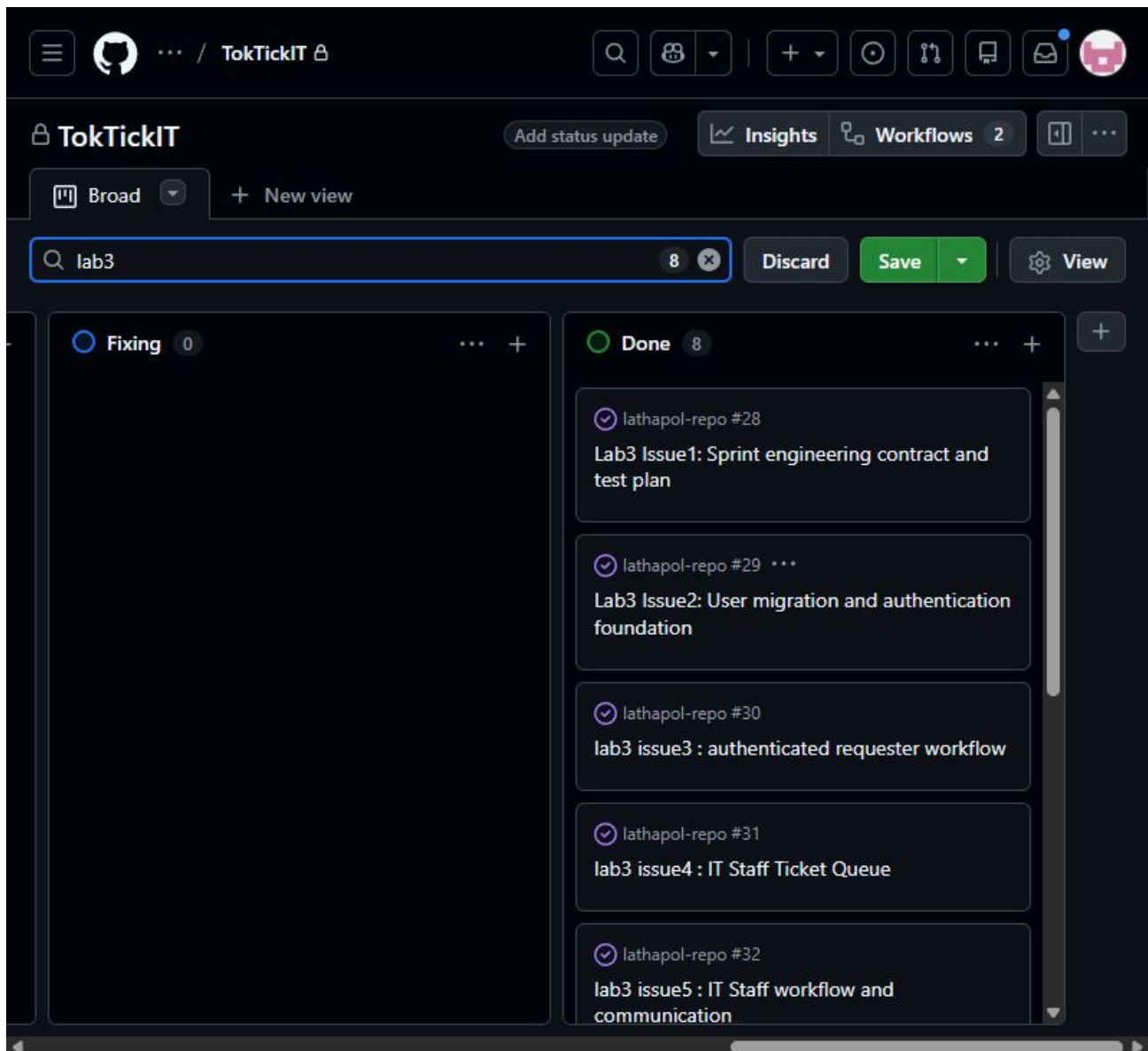
The GitHub Project visibly lists all eight Lab 3 issues in Done. Two unmodified screenshots capture the full list. The final nine-part PDF includes the release reviews, full final-main test outputs, traceability, AI-assisted reflection, and real responsive screenshots. The supplied Lab 2 PDF provided identity/layout reference.

Submission evidence is published separately from the tested application commit, so the test report retains the actual tested hash. No application code changed during final evidence preparation.

GitHub Project

PR #47 records the reviewed staging-to-main release. The Project showed all eight Lab 3 issues in Done on 16 September 2026. The following two screenshots cover the complete list.

GitHub Project - all eight Lab 3 items in Done

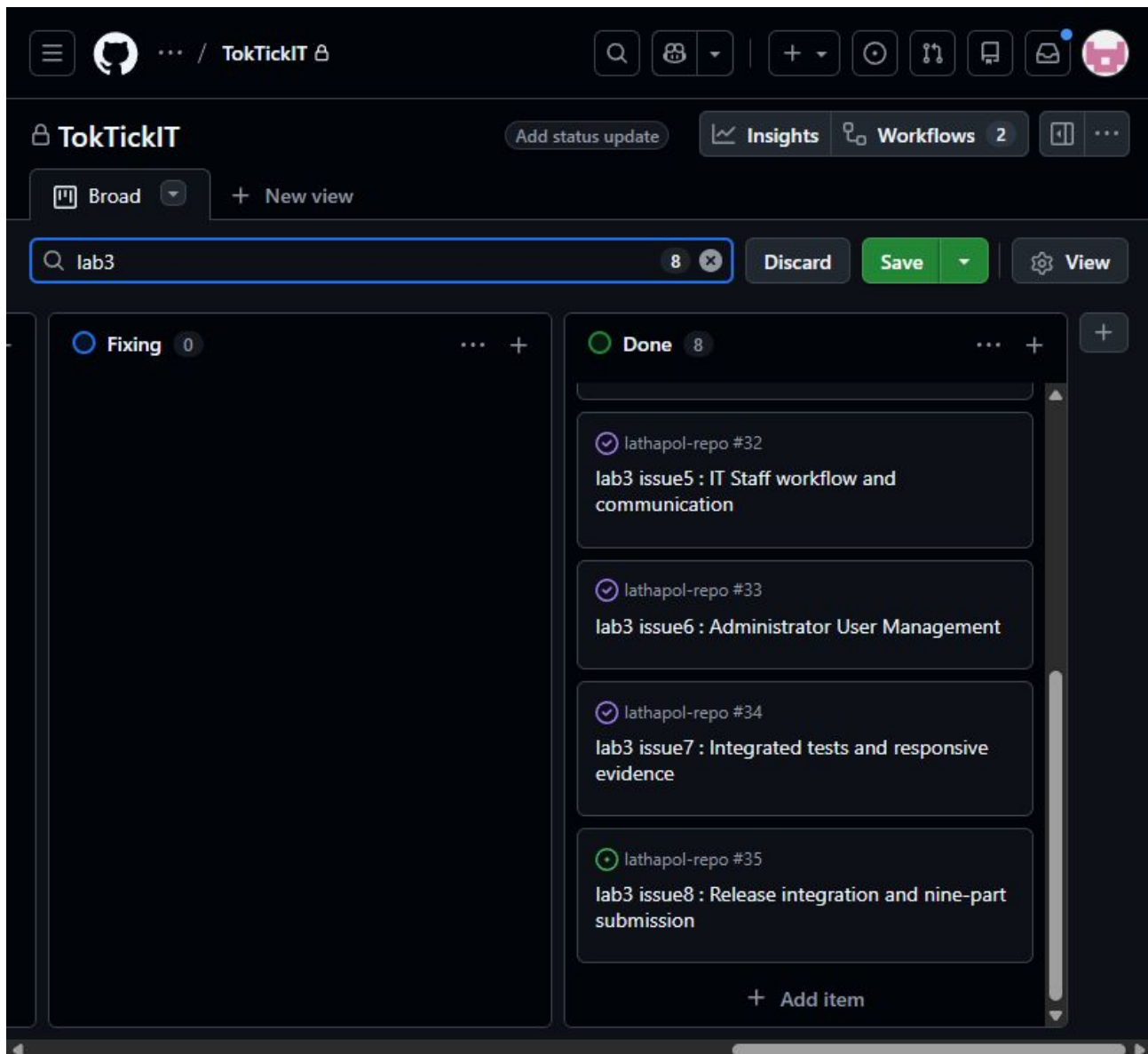


The screenshot shows a GitHub Project board for the repository 'TokTickIT'. The board is titled 'lab3' and has 8 items in the 'Done' column. The 'Fixing' column is empty. The 'Done' column contains the following items:

- lathapol-repo #28
Lab3 Issue1: Sprint engineering contract and test plan
- lathapol-repo #29 ***
Lab3 Issue2: User migration and authentication foundation
- lathapol-repo #30
lab3 issue3 : authenticated requester workflow
- lathapol-repo #31
lab3 issue4 : IT Staff Ticket Queue
- lathapol-repo #32
lab3 issue5 : IT Staff workflow and communication

The interface includes a search bar with 'lab3', a 'Discard' button, a 'Save' button, and a 'View' button. The board is organized into columns: 'Fixing' (0 items) and 'Done' (8 items).

GitHub Project - all eight Lab 3 items in Done



Repository setup and structure

[README and directory tree](#)

[Ignore rules](#)

[Environment example](#)

Root: client/ (React UI), server/ (API, Prisma migrations and tests), e2e/ (browser tests), docs/lab-03/ (contract and review records), artifacts/lab-03/ (real verification evidence), scripts/ (reproducible checks).

Answer Part 2

Specification-driven development

The original contract below is preserved as specification-first evidence. Its unchecked definition of done and planning notes describe the pre-implementation state; final completion is documented in Parts 1 and 3.

The contract was reviewed in PR #36 and merged before implementation PR #40. [Specification-first review](#).

[Repository source](#)

Sprint 3 engineering contract

Status: implementation baseline prepared from Lab_3_sheet.pdf and the existing Lab 2 repository. Student/peer review and final-main evidence remain required. This document precedes implementation; completion is not implied by its existence.

1. Sprint goal

Replace the development identity selector with secure accounts while preserving existing tickets and attachments. Give IT Staff a shared operational queue and give Administrators a small, safe user-management screen.

2. Stakeholder request

Requesters should use their own signed-in identity, communicate with support, and report apparent resolution. Staff should assign and progress tickets and keep internal discussion private. Administrators should manage accounts without becoming unrestricted ticket operators.

3. Scope

Included: login/logout/current user, mandatory password change, three single roles, migration, requester regression, queue, staff detail, ownership, IT priority, workflow, append-only comments/notes, minimal account administration, responsive Zen Green UI and tests.

Excluded: registration, email delivery/reset links, MFA/SSO, Actions Taken, SLA/escalation/notifications, analytics, departments, multiple roles, deletion/bulk/import/export, account history and cloud deployment.

4. Functional requirements

- FR-01 Authenticate active accounts and enforce initial-password replacement before normal APIs/screens.
- FR-02 Return a safe current user, invalidate logout sessions, enforce roles and ownership at the server.
- FR-03 Preserve Lab 2 create/list/detail/search/filter/sort/pagination and attachment upload/download/soft-remove using authenticated requester identity.
- FR-04 Offer a shared staff queue with search, combined status/IT-priority/owner filters, sorting, pagination and detail navigation.
- FR-05 Staff can claim unassigned tickets, assign/reassign eligible owners, change IT priority and perform permitted transitions.
- FR-06 Owners and staff can post Public Comments; staff can post Internal Notes. Readers follow the matrix below.

- FR-07 Requesters can indicate apparent resolution without changing formal ticket status.
- FR-08 Administrators can list/search/create/edit accounts, assign one role, activate/deactivate, and set an initial password.
- FR-09 Preserve data with a versioned migration and repeatable local seed.
- FR-10 All screens provide busy, validation, success, empty/no-results and safe failure feedback with responsive accessible controls.

5. Business rules

- BR-01 Only active users with correct credentials authenticate; unknown, inactive and incorrect credentials receive the same safe message.
- BR-02 A password-change-required session can access only current-user, change-password and logout endpoints.
- BR-03 Ignore client requesterId on all requester APIs. Derive author, requester and timestamps server-side. Cross-owner reads/writes return 404.
- BR-04 Public Comments are readable by the owning Requester, IT Staff and Administrator. Internal Notes are readable only by IT Staff and Administrator and are never included in requester detail responses.
- BR-05 Apparent resolution records a timestamp independently of status. Requesters cannot formally resolve/close; available only on nonterminal tickets, idempotent, cleared on reopening.
- BR-06 Normalize emails by trimming and lowercasing; enforce uniqueness in the database, including mixed-case duplicates. Names: 1-100 trimmed characters; email: valid basic structure and at most 254 characters.
- BR-07 Passwords are 12-128 characters, are not trimmed, must differ from the initial/current password, and must match confirmation. Store a random-salt scrypt hash (N=32768,r=8,p=3), never plaintext. Local-lab initial passwords are distributed manually, not emailed.
- BR-08 Store only SHA-256 digests of random 32-byte opaque session tokens in PostgreSQL. HttpOnly SameSite=Lax path=/ cookie, Secure in production, absolute 8-hour expiry. Login rotates the current session; password change/reset invalidates all sessions. User activation and role are checked on every request.
- BR-09 Require same-origin/allowlisted Origin on browser writes and a session-bound X-CSRF-Token for authenticated writes. Login accepts JSON only. Password failures are limited to 10 attempts per email per 15 minutes plus 100 per source IP; return 429 with Retry-After. This is a single-process lab limit.
- BR-10 Users have exactly one role: REQUESTER, IT_STAFF, ADMINISTRATOR. Deactivate instead of deleting. Deny self-deactivation and any demotion/deactivation of the last active administrator; serialize concurrent admin edits.
- BR-11 A ticket has zero or one owner, eligible only if active IT_STAFF or ADMINISTRATOR. Staff alone performs assignment/priority/status mutations. Administrator ownership is allowed by the handout but does not grant mutation rights. Existing ownership is retained when an account becomes inactive or changes role; reassign explicitly.
- BR-12 Requested Priority remains unchanged after creation. IT Priority is initially copied, then independently LOW/MEDIUM/HIGH. Existing tickets are backfilled from their requested priority.
- BR-13 Staff mutations require the current integer ticket version; stale writes/claims return 409. Staff must confirm terminal transitions. Status changes do not silently assign an owner.
- BR-14 Comments/notes are append-only, trimmed plain text, 1-4000 characters. React escapes rendering; no HTML interpretation. Author and time are server-generated. Comments remain available on terminal tickets.

- BR-15 Preserve Lab 2 summary 5-150, description 10-2000, active related system, category and priority validation. Attachment types JPG/PNG/WEBP/PDF, 5 MiB each, five active files, soft removal. Only owning Requesters upload/remove; staff/admin can read/download. Authorize before storing uploads and serialize the five-file limit.

- BR-16 APIs return safe structured errors: 400 validation, 401 unauthenticated, 403 role/password/CSRF restriction, 404 missing/foreign-owned, 409 conflict, 410 removed attachment, 429 throttled, 500 unexpected. Never send password hashes, tokens, disk paths, stack traces or note data to unauthorized users.

Authorization matrix

All permissions require an active account and completed password change unless noted.

Operation	Requester	IT Staff	Administrator
Current user / password / logout	Own, including initial session	Own	Own
Categories / related systems	Read	Read	Read
Create ticket / own ticket list	Own	Denied	Denied
Ticket detail / attachments download	Own only	All	All, read-only
Upload / soft-remove attachments	Own only	Denied	Denied
Shared queue / eligible owners	Denied	Read	Read
Claim / assign / priority / status	Denied	Allowed	Denied
Public Comments	Own: read/create	All: read/create	All: read
Internal Notes	Denied	All: read/create	All: read
Apparent resolution	Own nonterminal	Denied	Denied
User management	Denied	Denied	Allowed

Status transition matrix

Only IT Staff can use this matrix; all other transitions are rejected with 409. CLOSED and CANCELLED are terminal. No Actions Taken prerequisite in Lab 3.

From	Allowed destinations
NEW	OPEN, CANCELLED
OPEN	IN_PROGRESS, WAITING_FOR_REQUESTER, RESOLVED, CANCELLED
IN_PROGRESS	WAITING_FOR_REQUESTER, RESOLVED, CANCELLED
WAITING_FOR_REQUESTER	IN_PROGRESS, RESOLVED, CANCELLED
RESOLVED	CLOSED, REOPENED
REOPENED	OPEN, IN_PROGRESS, CANCELLED
CLOSED / CANCELLED	None

Confirmation is mandatory for RESOLVED, CLOSED and CANCELLED. Reopening clears requester apparent resolution. Initial status remains NEW.

6. UI specification summary

See ui-spec.md. Reuse Lab 2 tokens and attachment/create components. Login and password change precede a role-specific shell. Staff sees Queue; Admin sees Users plus read-only Queue; Requester sees My Tickets/Create Ticket. Public and private conversation sections have separate labeled composers.

7. Data changes

Map Prisma User to the existing PostgreSQL RequesterUser table using @@map, preserving IDs and ticket foreign keys. Add role, nullable passwordHash, mustChangePassword and updatedAt. Null hashes cannot authenticate; a local migration password initializer sets hashes only where missing. Check case-folded duplicate email conflicts before normalizing; stop safely rather than merging people.

Add Session(tokenHash PK, userId FK, csrfToken, expiresAt, createdAt), Ticket.ownerId FK/index, itPriority, version, requesterResolvedAt and the seven additional statuses. Add TicketEntry(ticketId, authorId, kind PUBLIC/INTERNAL, body, createdAt), indexed by ticket/kind/time. Keep Category, RelatedSystem and Attachment records and stored files unchanged. Migration uses additive SQL, no table/data reset. Capture before/after counts and existing ownership/attachment values; apply and test first on an isolated test database.

Seed only absent local fixtures: four active/one inactive Requesters, three active/one inactive Staff, one active Admin, 24 varied tickets with public/internal examples. Seed reruns do not overwrite changed passwords, roles, statuses or existing tickets. Legacy requester password initialization requires an explicit local password environment variable and never overwrites existing hashes.

8. API contract

See api-spec.md for endpoint shapes, session handling, validation and errors. Production hosting is excluded; Vite proxies /api to Express for same-origin cookie behavior locally.

9. Acceptance criteria

ID	Observable outcome
AC-01	Active valid login returns safe user/session; invalid/inactive rejected; attempts throttled.
AC-02	Initial session cannot reach normal APIs; valid different confirmed password unlocks app and invalidates old sessions.
AC-03	Logout/expiry/deactivation prevent reuse; cross-origin or missing-CSRF writes rejected.
AC-04	Spoofed requesterId cannot expose/change another user's tickets/attachments or set ownership on creation.
AC-05	Existing create/list/search/filter/sort/pagination and attachment constraints still work under login.
AC-06	Staff queue combines filters, sorts deterministically, paginates and rejects invalid queries.
AC-07	Eligible assignment/claim/priority work; inactive/requester assignees and stale versions fail.
AC-08	Every matrix transition works only for Staff; invalid/terminal/unconfirmed transitions fail.
AC-09	Public comments and notes preserve author/time and append-only privacy with content boundaries.
AC-10	Apparent resolution changes only the requester's signal; formal resolution stays Staff-only.
AC-11	Admin list/search/create/edit/role/activation/reset work; duplicates, invalid roles, self-deactivation and last-admin loss fail.
AC-12	Migration preserves old IDs, ownership, attachments and priorities; seeds are repeatable.
AC-13	Role shell and five major screens expose only permitted actions and cover busy/validation/success/failure.
AC-14	Desktop/tablet/mobile layouts have keyboard focus, labels, readable badges and no page overflow.

ID	Observable outcome
AC-15	End-to-end requester, staff and administrator flows pass using the real server/database.

10. Definition of Done

- [] AC-01 through AC-15 pass with traceable test files and actual outputs.
- [] Migration preservation and repeat seed evidence exist; Lab 2 regression passes.
- [] Backend and frontend builds and required test suites pass.
- [] Desktop/tablet/mobile screenshots visually reviewed; direct authorization evidence captured.
- [] README, specs, test plan, reviewer record and truthful AI-use record current.
- [] Feature PRs reviewed into lab3-staging, then main; tests rerun on final main; issues Done.
- [] Student supplies real peer-review identity/approvals and personal reflection.
- [] One concise PDF has Answer Part 1 through Answer Part 9, actual links and evidence.

11. Assumptions and decisions

Server-managed cookies avoid browser token persistence; sscript uses Node's built-in crypto to avoid a new hashing dependency. Admin can read queue/detail/notes to satisfy visibility rules but cannot mutate tickets. Owner eligibility includes Admin to follow section 4.5. The textual exclusions override example mockups showing email reset and service actions. Status policy and 12-character passwords are explicit project choices. No fabricated PR approvals, test results or historical prompts count as completion evidence.

Answer Part 3

Tests and traceability

[Repository source](#)

Lab 3 integrated verification

Tested final-main commit: 43e6c0605766586f7bacafde882da1a06ab1e9c2, merged in PR #47 and verified on 2026-09-16. The verification checkout was created directly from origin/main before any evidence edits. These outputs are from that exact main commit. Later submission-only edits do not change the application.

Results

PASS: 13 server suites / 160 tests; 7 client files / 26 tests; 15 browser scenarios; server TypeScript, client TypeScript and Vite builds. Migration preservation and repeated seed PASS. Full outputs are linked below.

Reproduce

Use Node.js and local PostgreSQL. Install root, server and client dependencies. Point ignored server/.env at the isolated toktickit_lab3_test database with migrated/seeded Lab 2 fixtures; the Jest guard refuses other database names. Never run tests against development data. Start the API from server with PORT=4103 and APP_ORIGIN=http://localhost:5183. Start Vite from client on port 5183 with VITE_API_URL=http://localhost:4103. Install Microsoft Edge for the configured Playwright channel.

From the repository root run `node scripts/verify-lab3.cjs`. It runs these commands sequentially and stops on failure:

Directory	Command
server	<code>node node_modules/jest/bin/jest.js --runInBand --testTimeout=15000</code>
server	<code>node node_modules/typescript/bin/tsc</code>
client	<code>node node_modules/vitest/vitest.mjs run</code>
client	<code>node node_modules/typescript/bin/tsc -b</code>
client	<code>node node_modules/vite/bin/vite.js build</code>
root	<code>node node_modules/@playwright/test/cli.js test --config playwright.lab3.config.ts</code>

[Machine-readable report](#) records the exact tested commit, commands and exit statuses. Its sibling .log files contain actual outputs and totals. The 15-second Jest deadline accommodates script tests on this machine without weakening assertions.

Executed coverage

Area / acceptance criteria	Actual test files
Password hashing/policy (AC01-02)	server/tests/lab-03/security.test.ts
Login, change gate, sessions, origin/CSRF, expiry, throttling (AC01-03)	server/tests/lab-03/auth.api.test.ts
Spoofed requester IDs, foreign reads/uploads, concurrent attachment limit (AC04-05)	server/tests/lab-03/requester.api.test.ts

Area / acceptance criteria	Actual test files
Lab 1/2 regression, create/list/search/filter/pagination/attachments (AC04-05)	server/tests/lab-01/*.test.ts; server/tests/lab-02/*.test.ts
Queue permissions, combined filters, stable sorting, pagination (AC06)	server/tests/staff-queue.test.ts
Ownership, every transition pair, confirmation, concurrent claims/updates, signal (AC07-08,10)	server/tests/workflow.test.ts
Public/private roles, boundaries, author/time, append-only methods (AC09)	server/tests/workflow.test.ts
Account CRUD scope, safe DTO, normalized duplicates, resets, self/last-admin races (AC11)	server/tests/users.test.ts
Initial password/session UI and requester components (AC02,05,13)	client/tests/lab-03/Auth.test.tsx; client/tests/lab-02/*.test.tsx
Queue feedback and filtering (AC06,13)	client/tests/lab-03/TicketQueue.test.tsx
Workflow confirmation/conflicts, privacy, safe text and signal (AC07,09-10,13)	client/tests/lab-03/TicketActivity.test.tsx
Account drafts, validation/errors, confirmations and password clearing (AC11,13)	client/tests/lab-03/Users.test.tsx
Real login/change/create/upload/download/remove/filter/reload/logout; keyboard Open (AC01-05,14-15)	e2e/lab-03/requester.spec.ts
Staff/admin queue and read-only attachment controls (AC06,14-15)	e2e/lab-03/queue.spec.ts
Staff claim/status/public/private posts, requester reply/signal, reopen, admin read-only (AC07-10,14-15)	e2e/lab-03/workflow.spec.ts
Admin create/edit/deactivate/reactivate/reset, mandatory new password (AC11,14-15)	e2e/lab-03/users.spec.ts

Migration and repeated seed (AC12)

Run `node scripts/verify-migration.cjs <Lab2-backup.dump> <PostgreSQL-bin-directory>`. It creates a new local evidence database, restores the supplied backup, compares every original column before/after the additive migration, checks IT priority backfill, seeds twice and compares complete rows. It never migrates the configured source database. A generated initial password stays only in the child process environment.

Migration report: all original rows/columns preserved for 5 users, 54 tickets, 9 attachment records, 4 categories and 7 related systems. The before/after digests match; zero priority mismatches. After seeding: 10 users, 78 tickets, 9 attachments, 48 entries. Both seed digests match, including stored password hashes. Attachment metadata and stored filenames are covered; physical-file download is exercised separately by requester E2E. The disposable evidence database is retained locally.

Responsive and accessibility evidence (AC13-14)

Playwright now runs all five scenarios at desktop 1440x1000, tablet 820x1180 and mobile 390x844. Screenshots use `artifacts/lab-03/issue7-<viewport>-...png`:

- login, password-change, create-ticket, tickets: requester workflow;
- IT_STAFF / ADMINISTRATOR: queue;
- staff / requester / admin: ticket detail and public/private sections;
- users / edit: account list and editor.

The visual review covers readable text/status badges, editable versus read-only controls, explicit private-note labeling, responsive cards, form wrapping and page overflow. Keyboard review identified mouse-only requester rows and sort headers; these now contain native buttons. Attachment upload/removal inputs now have accessible names. Focus outlines and an active administrator navigation state are explicit. Queue and requester Open actions are exercised with keyboard focus/Enter. Negative API/component tests cover validation, permission, conflict and failure feedback; screenshots document successful screens and password-reset feedback.

Peer approval and final-main verification completed: PR #47 and the recorded final-main report. The AI-assisted reflection is separate from these observed test results.

Final-main results

The recorded 160 server, 26 client and 15 browser tests passed on merged main commit 43e6c0605766586f7bacafde882da1a06ab1e9c2 on 16 September 2026. Every build and type check exited successfully. The complete terminal outputs follow; ANSI styling is removed and long lines wrap for readability.

server-tests full output - exit 0

server-build full output - exit 0

client-tests full output - exit 0

client-types full output - exit 0

client-build full output - exit 0

browser-tests full output - exit 0

server-tests - complete output

```
(node:12136) DeprecationWarning: Calling client.query() when the client is already executing a query is deprecated and will be removed in pg@9.0. Use async/await or an external async flow control mechanism instead.
(Use `node --trace-deprecation ...` to show where the warning was created)
```

```
Test Suites: 13 passed, 13 total
Tests:      160 passed, 160 total
Snapshots:  0 total
Time:       23.732 s, estimated 34 s
Ran all test suites.
```

server-build - complete output

(No terminal output; exit code 0.)

client-tests - complete output

```
RUN v4.1.10 C:/Users/User/Documents/Codex/2026-09-11/hel/work/toktickit-lab3/client
```

```
Test Files 7 passed (7)
  Tests 26 passed (26)
  Start at 17:19:27
  Duration 28.56s (transform 2.31s, setup 28.11s, import 6.86s, tests 6.20s, environment 150.47s)
```

client-types - complete output

(No terminal output; exit code 0.)

client-build - complete output

```
vite v8.2.1 building client environment for production...

transforming...PASS 29 modules transformed.
rendering chunks...
computing gzip size...
dist/index.html          0.46 kB ? gzip:  0.30 kB
dist/assets/index-CVNsST3H.css 237.97 kB ? gzip: 33.14 kB
```

dist/assets/index-DEwHr7At.js 241.74 kB ? gzip: 71.67 kB

PASS built in 1.96s

browser-tests - complete output

Running 15 tests using 1 worker

```
ok 1 [desktop] > e2e\lab-03\queue.spec.ts:10:6 > IT_STAFF queue filters, pagination and read-only detail (3.4s)
ok 2 [desktop] > e2e\lab-03\queue.spec.ts:10:6 > ADMINISTRATOR queue filters, pagination and read-only detail (1.9s)
ok 3 [desktop] > e2e\lab-03\requester.spec.ts:18:5 > login, first change, create with attachment, filter, reload, remove and logout (4.7s)
ok 4 [desktop] > e2e\lab-03\users.spec.ts:8:5 > admin creates, edits, deactivates and resets an account; user must change password (4.3s)
ok 5 [desktop] > e2e\lab-03\workflow.spec.ts:10:5 > staff workflow, private notes, requester signal and admin read-only view (6.5s)
ok 6 [mobile] > e2e\lab-03\queue.spec.ts:10:6 > IT_STAFF queue filters, pagination and read-only detail (3.2s)
ok 7 [mobile] > e2e\lab-03\queue.spec.ts:10:6 > ADMINISTRATOR queue filters, pagination and read-only detail (3.3s)
ok 8 [mobile] > e2e\lab-03\requester.spec.ts:18:5 > login, first change, create with attachment, filter, reload, remove and logout (4.3s)
ok 9 [mobile] > e2e\lab-03\users.spec.ts:8:5 > admin creates, edits, deactivates and resets an account; user must change password (8.0s)
ok 10 [mobile] > e2e\lab-03\workflow.spec.ts:10:5 > staff workflow, private notes, requester signal and admin read-only view (9.2s)
ok 11 [tablet] > e2e\lab-03\queue.spec.ts:10:6 > IT_STAFF queue filters, pagination and read-only detail (2.0s)
ok 12 [tablet] > e2e\lab-03\queue.spec.ts:10:6 > ADMINISTRATOR queue filters, pagination and read-only detail (1.8s)
ok 13 [tablet] > e2e\lab-03\requester.spec.ts:18:5 > login, first change, create with attachment, filter, reload, remove and logout (3.7s)
ok 14 [tablet] > e2e\lab-03\users.spec.ts:8:5 > admin creates, edits, deactivates and resets an account; user must change password (3.9s)
ok 15 [tablet] > e2e\lab-03\workflow.spec.ts:10:5 > staff workflow, private notes, requester signal and admin read-only view (4.9s)
```

```
15 passed (1.2m)
(node:18280) Warning: The 'NO_COLOR' env is ignored due to the 'FORCE_COLOR' env being set.
(Use `node --trace-warnings ...` to show where the warning was created)
(node:4344) Warning: The 'NO_COLOR' env is ignored due to the 'FORCE_COLOR' env being set.
(Use `node --trace-warnings ...` to show where the warning was created)
(node:9080) Warning: The 'NO_COLOR' env is ignored due to the 'FORCE_COLOR' env being set.
(Use `node --trace-warnings ...` to show where the warning was created)
```

Answer Part 4

AI use and reflection

Repository source

Lab 3 AI-use record

Assistant: OpenAI Codex, a GPT-6-based coding assistant. The exact model variant was not recorded. The Lab 2 PDF names Claude for the earlier lab; it is a formatting reference, not evidence of the assistant used for Lab 3.

Selected genuine user prompts (workflow messages, not invented implementation prompts):

1. Attached Lab_3_sheet.pdf with: "help me do this".
2. Provided <https://github.com/Lathapol/lathapol-repo> and the local TokTickIT directory.
3. "ok and too be effiecient pls sepearete each task ito issues like in the lab pdf and told me accordfinly when each issues is finsih so i can tell my co worker to merge our pull request"
4. "oh too told you a nit every time when we do the issues commented amke it short and like me you can look to my preview work , and when my freind comment back and merge also comment to their response comment"
5. Clarified: "lab3 issues 2 sory".
6. "oh and after this i prefer the name lab3 issueX : name_____"
7. "how much issues left?"
8. "i'll send you my lab2 pdf submission file can you look at that for ref?"

Issue 2: Codex implemented and tested the additive migration, password hashing, cookie sessions, first-password gate, CSRF/origin checks and repeatable fixtures. A failing attachment regression led to sharing and creating the upload directory. Tests and build were run against an isolated database; migration preservation and repeated seed results are recorded in issue-02.md. No personal reflection or peer implementation approval has been fabricated.

Work: inspected the handout and Lab 2 repository; drafted engineering contract, API/UI specifications and test plan before implementation. Implementation/testing results will be added as observed. Files in the handout were treated as requirements for the assignment, not instructions to fabricate evidence or approvals.

My Reflection (AI-assisted)

The main lesson from this lab is that authentication changes the whole workflow, not only the login screen. The server must check roles and ticket ownership even when the UI hides an action. The distinction between Public Comments and Internal Notes made this especially clear: private information must be excluded from unauthorized API responses.

Separating the work into issues and pull requests gave each feature a clear review point. The specification established decisions such as staff-only status changes and read-only administrator ticket access before implementation. Coding assistance helped turn those decisions into working screens and tests. Problems such as competing ticket claims and last-administrator changes needed concurrency tests, while the browser checks caught responsive selector and keyboard-access issues that API tests alone could not show.

For future work, I would keep the same specification-first sequence and use both API and browser evidence before considering a feature complete. Short review replies keep the workflow moving, but the detailed test logs and specification links are what make the result easier to verify.

This draft was written by the assistant at the student's request, using the recorded workflow and actual review history. It does not assert that the student personally executed the assistant's tests. The student should read this AI-assisted wording before submission.

Implementation record

Issue 3 continuation: user requested the `lab3 issuex : name title style` and said "continue" after issue 2. Codex implemented login/session UI and requester integration, added API and browser tests, corrected missing create-form uploads and concurrent upload counting, and inspected responsive screenshots. Actual counts are in `issue-03.md`. PR #40 approval and the short author reply are recorded in `reviewer.md`.

The selected prompts above are actual messages from this conversation. Detailed technical plans generated by the assistant are not attributed to the student as historical prompts.

Issue 4 continuation: user said "continue". Codex implemented the shared queue API/UI, permission/filter/pagination tests, read-only detail integration and responsive browser checks. Corrected test fixture email casing after a login test failure. Actual results and evidence are in `issue-04.md`; the completed peer review is recorded in `reviewer.md`.

Issue 5 continuation: user said "continue on". Codex implemented staff workflow, append-only communication and requester apparent resolution, tested all transition pairs and concurrent writes, and verified role privacy through real APIs and browser flows. Fixed an E2E select locator after a timeout. Evidence is in `issue-05.md`; the completed peer review is recorded in `reviewer.md`.

Issue 6 continuation: user said "next". Codex implemented administrator account management, password resets/session invalidation, serialized last-admin safeguards, component tests and responsive browser checks. A void-result decoding error in the advisory-lock query was corrected; the existing password-throttle test required a longer timeout on this machine. Actual results are in `issue-06.md`. Peer approval is recorded in `reviewer.md`.

Issue 7 continuation: user said "continue". Codex ran integrated verification, expanded tablet/browser evidence, restored the Lab 2 backup into a fresh local evidence database to verify migration and repeated seeds, corrected requester keyboard controls/attachment labels, and recorded exact commits, commands and results. No personal reflection or final-main success has been invented.

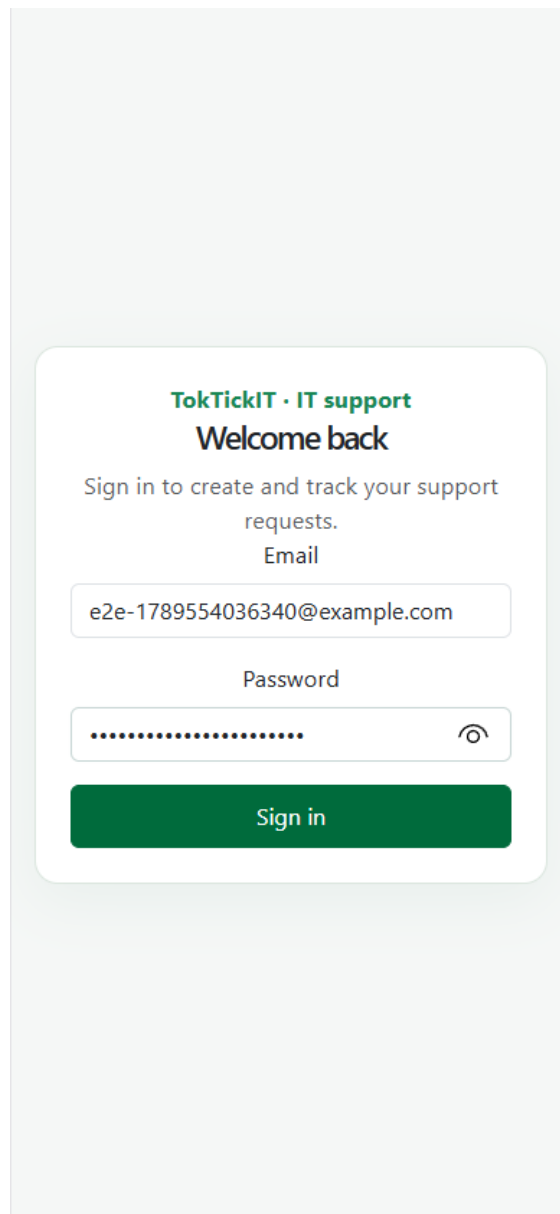
Answer Part 5

Login, mandatory password change and requester UI

Real-browser scenarios cover login, initial password change, authenticated create/upload/list/detail and logout. API and component tests cover invalid/inactive credentials, failed requests, busy states and direct role/ownership rejection. See Answer Part 3 for exact test paths. Screenshots show successful states; they do not independently prove every negative case.

Login

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

A mobile app login screen for 'TokTickIT · IT support'. The screen has a light gray background. In the center is a white rounded rectangle containing the login form. At the top of the form, it says 'TokTickIT · IT support' in green and 'Welcome back' in black. Below that, it says 'Sign in to create and track your support requests.' in gray. There are two input fields: 'Email' with the value 'e2e-1789554036340@example.com' and 'Password' with a masked password '.....'. To the right of the password field is an eye icon. At the bottom of the form is a green button with the text 'Sign in' in white.

[Open original PNG](#)

Mandatory password change

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

TokTickIT · IT support

Change your initial password

Set your own password before accessing your tickets.

Current password

New password

12-128 characters, different from your current password.

Confirm new password

[Change password](#)

[Sign out](#)

[Open original PNG](#)

Authenticated ticket creation

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

TokTickIT

My Tickets

Create Ticket

Requester: **Browser Test**

Sign out

Create Ticket

Requester

Browser Test

Category *

Account and Access

Related System *

Email

Requested Priority

Medium

Summary *

Browser workflow verification

Description *

Verify authenticated creation and attachment persistence.

Attachments

Choose Files

No file chosen

Up to 5 files. JPG, PNG, WEBP, or PDF only. Max 5 MB each.

example.pdf

0 KB

Remove

Submit Ticket

[Open original PNG](#)

Answer Part 6

IT Staff ticket queue

Queue API tests cover combined filters, stable sorting and pagination. Browser scenarios open tickets for staff and read-only administrators. Component checks cover loading, empty and failure states.

IT Staff queue

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

TokTickIT

Queue Reviewer · IT Staff

Sign out

Ticket Queue

Find and review support tickets across the team.

Search

Ticket number or summary

Status

All statuses

IT priority

All priorities

Owner

All owners

Category

All categories

Sort by

Created date

Order

Descending

Per page

10

Apply filters

Reset

162 tickets

TKT-2026-000138

Browser workflow verification

MEDIUM

NEW

Requester: Browser Test

Owner: Unassigned

Updated: 9/16/2026, 5:20:16 PM

Open

TKT-2026-000137

Valid summary text

MEDIUM

NEW

Requester: Jennifer Anderson

Owner: Unassigned

Updated: 9/16/2026, 5:19:20 PM

Open

TKT-2026-000136

Test ticket summary

MEDIUM

NEW

Requester: Jennifer Anderson

Owner: Unassigned

Updated: 9/16/2026, 5:19:20 PM

Open

TKT-2026-000135

[Open original PNG](#)

IT Staff queue (continued)

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

TKT-2026-000135 Unique searchable phrase xyz LOW NEW Requester: Jennifer Anderson Owner: Unassigned Updated: 9/16/2026, 5:19:18 PM Open	Open
TKT-2026-000134 Isolation test summary LOW NEW Requester: Jennifer Anderson Owner: Unassigned Updated: 9/16/2026, 5:19:18 PM Open	TKT-2026-000131 Browser workflow verification MEDIUM NEW Requester: Browser Test Owner: Unassigned Updated: 9/15/2026, 5:11:07 PM Open
TKT-2026-000133 Attachment test ticket LOW NEW Requester: Jennifer Anderson Owner: Unassigned Updated: 9/16/2026, 5:19:18 PM Open	TKT-2026-000130 Browser workflow verification MEDIUM NEW Requester: Browser Test Owner: Unassigned Updated: 9/15/2026, 5:10:44 PM Open
TKT-2026-000132 Browser workflow verification MEDIUM NEW Requester: Browser Test Owner: Unassigned Updated: 9/15/2026, 5:11:30 PM	TKT-2026-000129 Valid summary text MEDIUM NEW Requester: Jennifer Anderson Owner: Unassigned Updated: 9/15/2026, 5:09:42 PM Open
Previous Page 1 of 17 Next	

[Open original PNG](#)

Answer Part 7

Staff workflow and communication

Workflow tests exercise ownership, competing claims, every status transition pair, confirmation, public/private communication, requester resolution signal and role restrictions. Real browser flows verify claim, status updates, public comments, internal notes, requester reply/signal and reopening.

Staff ticket detail

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

TokTickIT Support Staff · IT Staff Sign out

[Back to Ticket Queue](#)

Ticket No.
WF-BROWSER-1789554048873

Created Date
9/17/2026, 12:20:49 AM

Category
Account and Access

Related System
Email

Requested Priority
LOW

Current Status

OPEN

Last Updated
9/16/2026, 5:20:50 PM

Summary
Workflow browser 1789554048873

Description
The printer is unavailable. Please investigate.

Ticket workflow
Requester: Test Requester
Owner: Support Staff
IT priority: HIGH
Status: OPEN
Owner
Support Staff

IT priority

[Open original PNG](#)

Staff ticket detail (continued)

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

HIGH

Change status

Keep OPEN

Save changes

Public Comments

Visible to the requester and support team.
Comment posted.

Support Staff 9/16/2026, 5:20:52 PM
Please try printing again.

New public comment

0/4000 characters · Entries cannot be edited or deleted.

Post comment

Internal Notes

Private: visible only to IT Staff and Administrators.
Internal note posted.

Support Staff 9/16/2026, 5:20:52 PM
Private diagnosis: inspect the print service.

New internal note

0/4000 characters · Entries cannot be edited or deleted.

Post internal note

Attachments (0/5 active)

[Open original PNG](#)

Requester ticket detail

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

TokTickIT

[My Tickets](#)

[Create Ticket](#)

Requester: **Test Requester**

[Sign out](#)

[Back to My Tickets](#)

Ticket No.

WF-BROWSER-1789554048873

Created Date

9/17/2026, 12:20:49 AM

Category

Account and Access

Related System

Email

Requested Priority

LOW

Current Status

OPEN

Last Updated

9/16/2026, 5:20:53 PM

Summary

Workflow browser 1789554048873

Description

The printer is unavailable. Please investigate.

Ticket workflow

Requester: Test Requester
Owner: Support Staff
IT priority: HIGH
Status: OPEN
Requester reported apparent resolution on 9/16/2026, 5:20:53 PM. Formal status: OPEN.

Public Comments

Visible to the requester and support team.
Comment posted.

Support Staff 9/16/2026, 5:20:52 PM

Please try printing again.

Test Requester 9/16/2026, 5:20:55 PM

Printing works now, thanks.

New public comment

0/4000 characters · Entries cannot be edited or deleted.

[Post comment](#)

Attachments (0/5 active)

[Choose File](#)

No file chosen

[Open original PNG](#)

Answer Part 8

Administrator user management

API tests cover normalized duplicate emails, safe responses, resets and session revocation, self-deactivation and concurrent last-administrator protection. Browser flows create, edit, deactivate, reactivate and reset an account, then require its new password.

Administrator users

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

TokTickIT Users Ticket Queue

Account Administrator · Administrator

Sign out

User Management

Create accounts and manage access to TokTickIT.

Account created. Share the initial password privately.

Search name or email

created-ui-1789554041038@example.test

Filter role

All roles

Search Reset filters

Create account

1 accounts

New Support Account

created-ui-1789554041038@example.test

IT STAFF · Active

Password change required

Edit

[Open original PNG](#)

Edit user

Original mobile capture, 390 x 844 viewport. Consecutive vertical excerpts; image content is unchanged.

The screenshot displays the TokTickIT User Management interface. The top navigation bar is dark green with the TokTickIT logo, a 'Users' button, and a 'Ticket Queue' button. Below the navigation bar, the user's role is shown as 'Account Administrator · Administrator' with a 'Sign out' button. The main section is titled 'User Management' with a subtitle 'Create accounts and manage access to TokTickIT.' The 'Edit account' section includes a message about the initial password and a form for the user's name and email. The 'Set initial password' section includes a message about the password requirements and a form for the new password, with a checkbox to confirm the password reset and sign out existing sessions.

TokTickIT Users Ticket Queue

Account Administrator · Administrator

Sign out

User Management

Create accounts and manage access to TokTickIT.

Edit account

Initial password set. Existing sessions ended; password change is required at next login.

Name

New Support Account

1–100 characters.

Email

created-ui-1789554041038@example.tes

Use a unique email address.

Role

REQUESTER

☒ Active account

Save account Cancel

Set initial password

This signs the user out and requires a password change at next login.

New initial password

12–128 characters; different from the current password.

☐ Confirm password reset and sign out existing sessions

Set initial password

[Open original PNG](#)

Answer Part 9

Zen Green and responsive UI

[Repository source](#)

Lab 3 UI specification

Reuse Lab 2 Zen Green: primary #006B3C, secondary #0B7A46, pale #EAF6EF, page #F5F7F6, text #1F2A24, read-only #EDF1EE, error #B3261E. White editable fields, labeled buttons, 16px base type, 8px spacing unit, 16px form gaps, 32px sections. Shared Badge, Feedback and form controls across new screens; keep CreateTicket and AttachmentPicker.

Screen / mode	Structure and behavior
Login	Centered card; labeled email/password, validation, busy disabled submit; identical safe message for wrong/inactive/unknown credentials.
Change password	Blocking card, current/new/confirm, rules shown, inline mismatch/length feedback. Successful change replaces the session then enters role home. Logout remains available.
Shell	Brand, current name and text role, role navigation, logout. Requester: My Tickets/Create; Staff: Queue; Admin: Users/Read-only Queue. No development selector. Reload verifies /auth/me.
Requester list/create/detail	Existing Lab 2 behavior with authenticated identity. All eight status filters. Detail adds Public Comments and apparent-resolution action for nonterminal tickets. No note section or formal status control.
Queue / view	Heading, result count, search, status, IT priority and owner filters, sort/order. Desktop table: ticket/summary, requester, owner, priority, status, updated and Open. Mobile/tablet cards avoid a wide grid. Pagination Previous/Next and page metadata.
Staff detail / view-edit	Read-only ticket header/description/category/system/requested priority. Separate operational card for owner, IT priority and allowed next status; Claim and Save, current version carried with updates. Confirm terminal changes explicitly. Stale conflict tells user to reload.
Conversation / append	Public Comments and Internal Notes are separate labeled panels and composers, with visibility helper text. No editing/deletion. Author/time and escaped prewrapped text. Private note composer never reuses a public draft. Admin sees read-only panels.
Users / list-create-edit	Name/email search and optional role filter. List name/email/role/status/Edit. Create/edit form name,email,one role,active; initial password only on create. Separate reset form on edit. Confirm deactivation/reset; API errors preserve draft. Self-deactivation disabled with reason; last-admin loss rejected safely.

Feedback: each async read has loading, safe failure and Retry; list distinguishes zero records from filtered no-results. Writes disable while saving; errors role=alert, successes role=status. Field rules appear near labels and use aria-describedby/aria-invalid when invalid. Existing values/drafts persist after failures. Button text distinguishes Claim, Save changes, Post comment and Add internal note. Reset and logout clear credentials/session state; expired or revoked sessions return to login. No success is shown until backend success.

Responsive: >=992px desktop tables and multi-column detail; 768-991px cards/two-column forms; <768px stacked fields/nav, wrapping buttons and long filenames/email/body. Container max-width 1200px, no page overflow. Buttons min 44px on mobile. Focus-visible ring and keyboard reachable native controls; text badges never communicate via color alone. Only allowed fields are editable.

Visual evidence to collect at 1440x1000, 820x1180 and 390x844: login, mandatory change password, queue, staff detail, users; preserve requester regression coverage. Checklist: colors, spacing, active role navigation, correct fields/read-only state, private label, contrast, focus, inline validation, wrapping, clipping/overlap/overflow, busy and safe failure. Mark checks only after actual inspection.

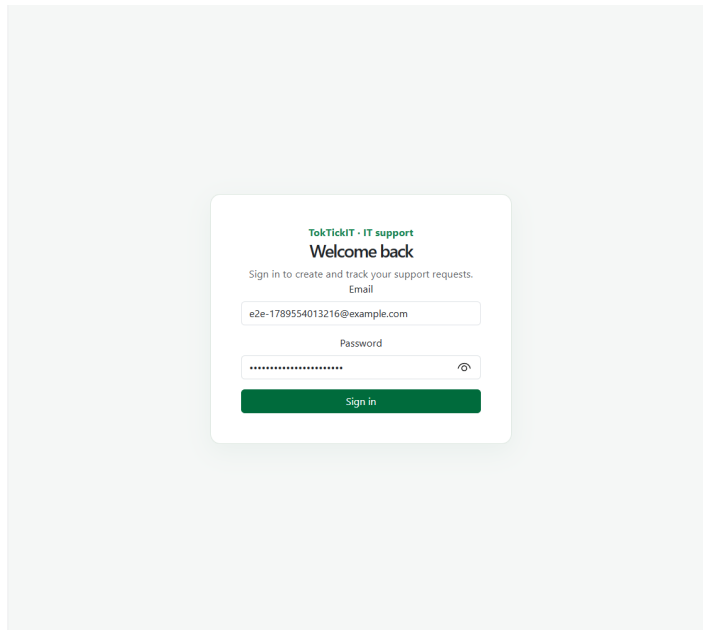
Completed inspection record

The issue 7 verification record documents visual inspection across desktop, tablet and mobile, plus native keyboard controls, labels, role navigation, text badges, wrapping and absence of page overflow. Mobile excerpts appear in Parts 5-8. The following desktop/tablet images show layout overviews; linked originals provide full detail.

[Completed visual checklist](#)

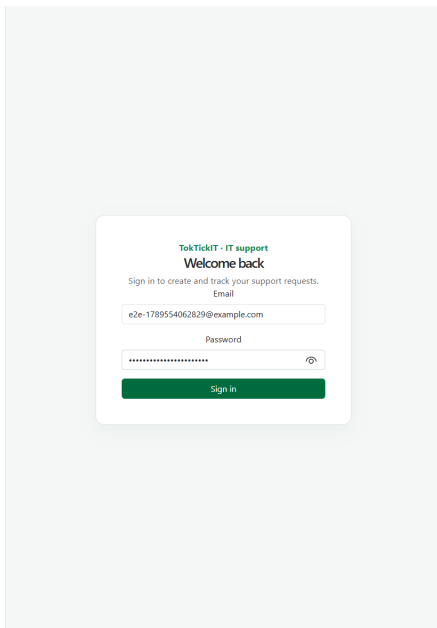
login - responsive comparison

Desktop - login



Full-resolution screenshot

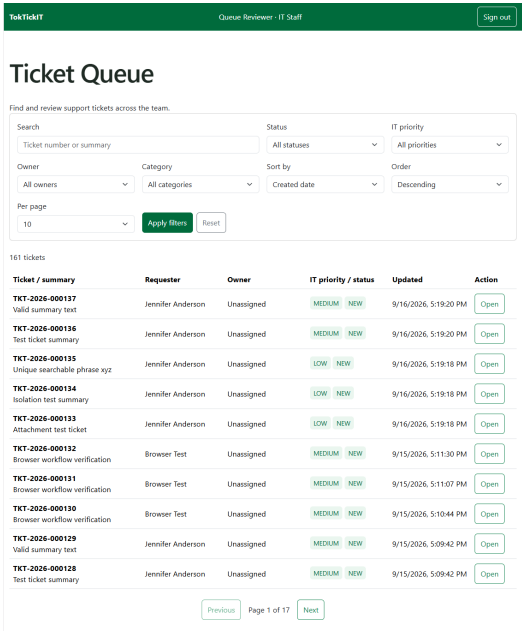
Tablet - login



Full-resolution screenshot

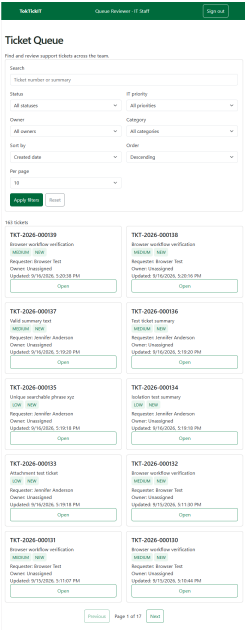
IT_STAFF - responsive comparison

Desktop - IT_STAFF



Full-resolution screenshot

Tablet - IT_STAFF



Full-resolution screenshot

staff - responsive comparison

Desktop - staff

TicketIT Support Staff - IT Staff [Sign out](#)

[Back to Ticket Queue](#)

Ticket No. WF-88040632-1789554020499 Created Date 9/17/2026, 12:20:27 AM Category Account and Access Related System Email

Requested Priority **LOW** Current Status **OPEN** Last Updated 9/16/2026, 5:20:24 PM

Summary Workflow browser: 1789554020499

Description The printer is unavailable. Please investigate.

Ticket workflow

Requester: Test Requester
Owner: Support Staff
IT priority: HIGH
Status: OPEN
Owner: IT priority: Change status:

Public Comments

Visible to the requester and support team.
Comment posted:
Support Staff 9/16/2026, 5:20:24 PM
Please try printing again.
New public comment:
14000 characters. Replies cannot be edited or deleted.

Internal Notes

Private: visible only to IT Staff and Administrators.
Internal note posted:
Support Staff 9/16/2026, 5:20:24 PM
Printer diagnosis: inspect the print service.
New internal note:
14000 characters. Replies cannot be edited or deleted.

Attachments (0/5 active)

Full-resolution screenshot

Tablet - staff

TicketIT Support Staff - IT Staff [Sign out](#)

[Back to Ticket Queue](#)

Ticket No. WF-88040632-1789554020499 Created Date 9/17/2026, 12:21:11 AM Category Account and Access Related System Email

Requested Priority **LOW** Current Status **OPEN** Last Updated 9/16/2026, 5:21:12 PM

Summary Workflow browser: 1789554020499

Description The printer is unavailable. Please investigate.

Ticket workflow

Requester: Test Requester
Owner: Support Staff
IT priority: HIGH
Status: OPEN
Owner: IT priority: Change status:

Public Comments

Visible to the requester and support team.
Comment posted:
Support Staff 9/16/2026, 5:21:12 PM
Please try printing again.
New public comment:
14000 characters. Replies cannot be edited or deleted.

Internal Notes

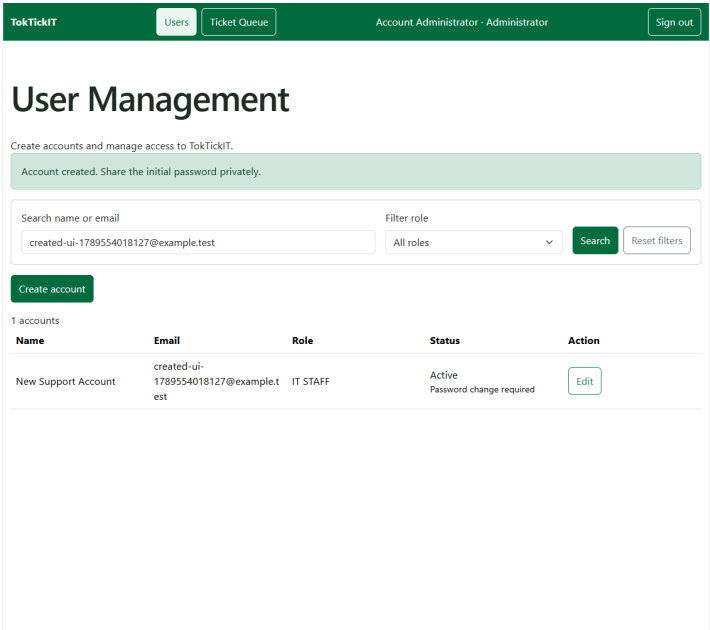
Private: visible only to IT Staff and Administrators.
Internal note posted:
Support Staff 9/16/2026, 5:21:12 PM
Printer diagnosis: inspect the print service.
New internal note:
14000 characters. Replies cannot be edited or deleted.

Attachments (0/5 active)

Full-resolution screenshot

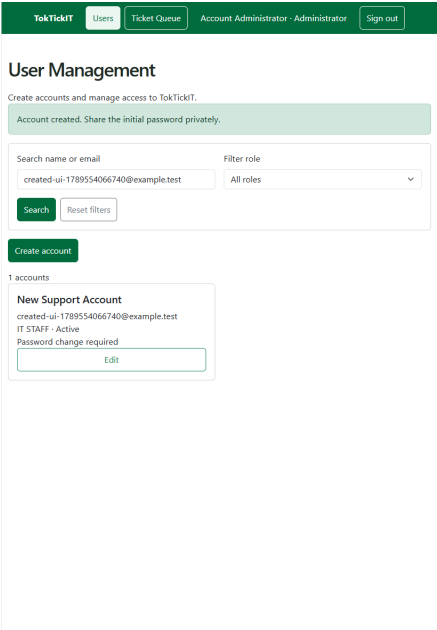
users - responsive comparison

Desktop - users



Full-resolution screenshot

Tablet - users



Full-resolution screenshot